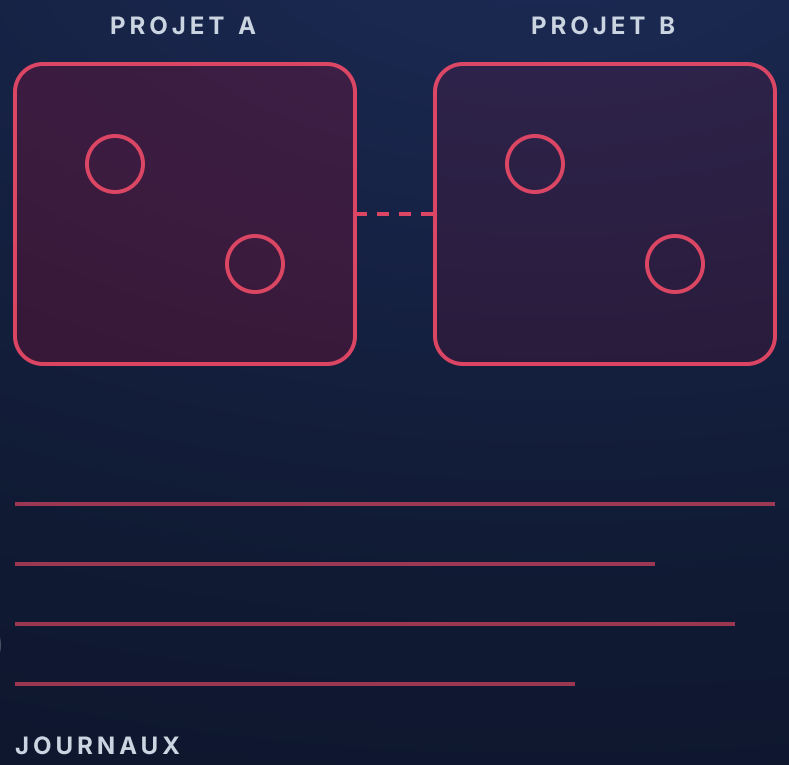
COMPRENDRE OPENSTACK · MODULE 13

Micro-segmentation, audit et traçabilité

Réseaux partagés et réseaux privés, isolation entre locataires, groupes de sécurité ; journalisation des services, corrélation et centralisation des journaux, sur Canonical OpenStack (Sunbeam)



Neutron · OVN | RBAC réseau | Groupes de sécurité | Identifiants de requête | CADF | Loki · Grafana

Version déployée : Canonical OpenStack 2026.1 LTS, donc OpenStack 2026.1 · ANSSI, architecture d'un système de journalisation · CNIL, recommandation journalisation (2021)

INTRODUCTION

Objectif et déroulé

Objectif : isoler réellement les locataires et les composants d'une application sur le réseau, puis être capable de répondre, après coup, à « qui a fait quoi, quand, d'où, avec quel résultat » — en centralisant et en corrélant les journaux du cloud.

À l'issue de ce module, vous saurez :

- Expliquer ce qui isole deux projets dans **Neutron et OVN**.
- Choisir entre **réseau partagé**, **réseau privé** et partage ciblé par RBAC.
- Concevoir une **micro-segmentation** par groupes de sécurité et la tester.
- Retrouver une action dans les journaux grâce aux **identifiants de requête** et aux événements d'audit.
- Centraliser les journaux d'un cloud Sunbeam et écrire des **règles d'alerte** utiles.

1 · Le réseau d'un cloud Sunbeam
Briques de Neutron, OVN, ce qui isole deux projets.

2 · Partagé ou privé
Réseaux de projet, partage, RBAC, réseau externe, exposition.

3 · Groupes de sécurité et micro-segmentation
Règles, groupe distant, application à trois niveaux, OVN, journalisation des flux.

4 · Journalisation des services
Sources, identifiants de requête, événements, CADF.

5 · Corrélation et centralisation
Observabilité Sunbeam, requêtes, scénario d'enquête, alertes, conservation.

01

Le réseau d'un cloud Sunbeam

Avant de cloisonner, il faut savoir ce que l'on cloisonne. Neutron décrit le réseau ; OVN le réalise sur chaque hyperviseur. L'isolation entre projets est une propriété de ce couple.

- Les briques de Neutron
- Trois catégories de réseaux
- Le chemin d'un paquet
- Neutron et OVN sur Sunbeam
- Ce qui isole deux projets
- Ce que Sunbeam crée à l'installation

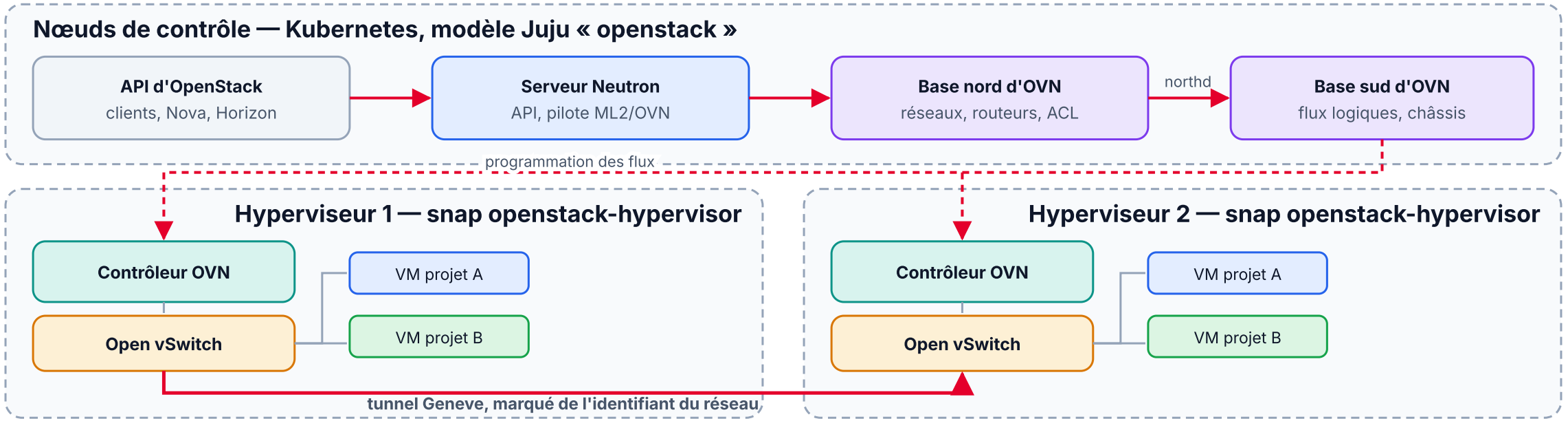
Les briques de Neutron

Objet	Rôle	Appartient à	Point de cloisonnement
Réseau	**segment de niveau 2, isolé des autres réseaux**	un projet	partagé ou non
Sous-réseau	**plage d'adresses, passerelle, DHCP, DNS**	un projet	plages qui peuvent se recouvrir entre projets
Port	**point de raccordement d'une instance, d'un routeur, d'un service**	un projet	porte les groupes de sécurité et la sécurité de port
Routeur	**relie des sous-réseaux entre eux et vers le réseau externe**	un projet	seul passage entre réseaux
Adresse flottante	**adresse du réseau externe associée à un port**	un projet	seul moyen d'être joint de l'extérieur
Groupe de sécurité	**ensemble de règles de filtrage appliquées aux ports**	un projet	micro-segmentation
Politique RBAC	**partage d'un objet avec un ou plusieurs projets**	le propriétaire	ouverture contrôlée

Tout appartient à un projet : c'est ce qui permet de cloisonner. Un objet partagé l'est toujours explicitement, par une politique RBAC.

Les modules précédents ont traité le cloisonnement par l'identité, les projets et les quotas ; celui-ci traite la couche réseau et la traçabilité.

Neutron et OVN sur Sunbeam



- **Neutron décrit,** OVN réalise : chaque réseau devient un commutateur logique, chaque routeur un routeur logique, chaque groupe de sécurité un ensemble de règles de filtrage (ACL).
- **Le plan de contrôle** — serveur Neutron, bases nord et sud d'OVN — tourne dans Kubernetes sur les nœuds de contrôle.
- **Le plan de données est distribué :** le contrôleur OVN de chaque hyperviseur programme Open vSwitch localement ; le filtrage se fait au plus près de l'instance.
- **Entre hyperviseurs,** le trafic des réseaux de projet circule dans des tunnels Geneve, marqué de l'identifiant de son réseau.

Trois catégories de réseaux

Catégorie	Créé par	Transport	Visible par	Usage
Réseau de fournisseur, externe	**l'administration**	réseau physique : à plat ou VLAN	tous, ou certains projets	sortie vers l'extérieur, adresses flottantes
Réseau privé de projet	**le projet**	superposé : tunnels Geneve	le projet seul	cas général des applications
Réseau partagé	**l'administration, ou un projet propriétaire**	superposé ou fournisseur	les projets autorisés	services communs, administration

Réseau superposé

Créé librement par les projets, sans toucher au réseau physique. Les adresses de deux projets peuvent se recouvrir : `10.0.0.0/24` dans chacun, sans conflit.

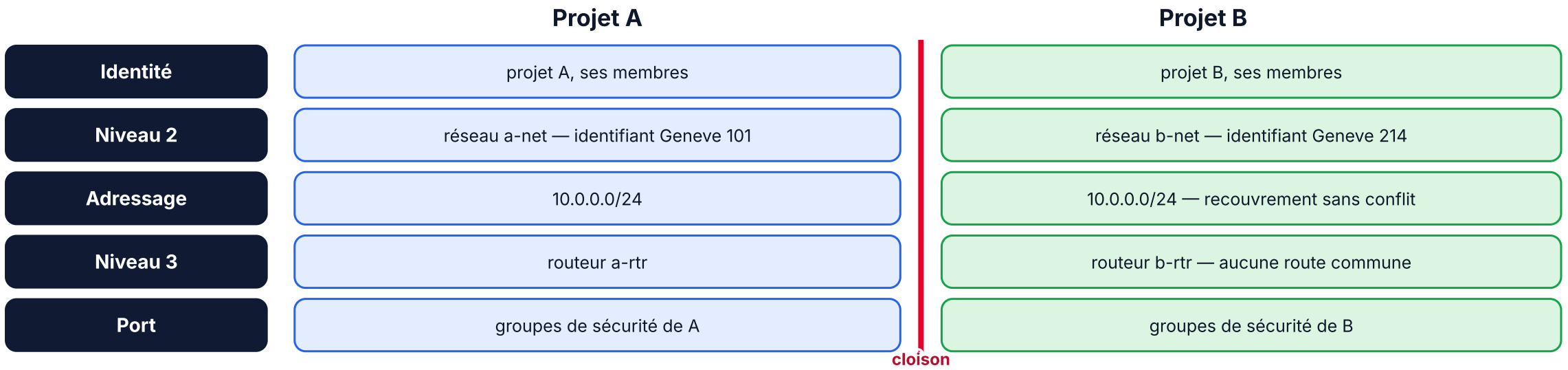
Réseau de fournisseur

Correspond à un réseau physique existant. Seule l'administration le déclare, car il engage l'infrastructure réelle : VLAN, routage, pare-feu de l'entreprise.

Partagé n'est pas une technologie

C'est un attribut d'accès. Un réseau superposé comme un réseau de fournisseur peut être partagé, avec tous ou quelques projets.

Ce qui isole deux projets



Par défaut, deux projets ne se voient pas : réseaux distincts, adresses indépendantes, aucun routeur commun. Pour communiquer, ils doivent passer par le réseau externe et des adresses flottantes — comme deux entreprises sur Internet.

Chaque couche se défait par une décision explicite : un réseau partagé, un routeur commun, un groupe de sécurité trop ouvert, une sécurité de port désactivée. La suite du module passe ces décisions en revue.

Le chemin d'un paquet entre deux projets



- **Quatre contrôles successifs :** groupe de sécurité de sortie de A, traduction d'adresse par le routeur de A, routeur de B qui traduit l'adresse flottante, groupe de sécurité d'entrée de B.
- **Le groupe de sécurité de B** voit l'adresse source traduite de A — l'adresse de passerelle de son routeur —, pas son adresse privée.
- **Avec OVN,** routage et traduction d'adresses sont distribués : le paquet peut ne jamais quitter l'hyperviseur, et pourtant subir les mêmes contrôles.
- **Sans adresse flottante sur B,** aucun chemin : B est injoignable depuis A.

Ce que Sunbeam crée à l'installation

Objet	Créé par
Réseau externe et son sous-réseau	`sunbeam configure` : plage, passerelle, plage d'adresses flottantes, type à plat ou VLAN
Réseau et routeur du projet de démonstration	`sunbeam configure`
Règles ouvrant SSH et ping	`sunbeam configure`, sur le groupe par défaut du projet de démonstration
Groupe `default` de chaque projet	Neutron, à la première utilisation du projet

Le projet de démonstration a un groupe par défaut ouvert en SSH et ping depuis partout : pratique pour valider l'installation, à ne pas reproduire ailleurs, et à supprimer en production.

```
# Prérequis : identifiants d'administrateur
sunbeam openrc > admin-openrc
source admin-openrc

# Réseaux : externe, partagé, privé, et leur type
openstack network list --long \
  -c Name -c Project -c Shared -c "Router Type" \
  -c "Network Type"

# Qui partage quoi avec qui
openstack network rbac list --long

# Routeurs et leur passerelle externe
openstack router list --long

# Groupes de sécurité ouverts sur 0.0.0.0/0
openstack security group rule list --long \
  --ingress -f value -c ID -c "IP Range" \
  -c "Port Range" -c "Security Group" | grep 0.0.0.0/0
```

Colonnes affichées selon la version du client ; `-f yaml` montre tous les champs.

02

Réseaux partagés et réseaux privés

Un réseau partagé met plusieurs projets sur le même segment : il n'y a plus de cloison de niveau 2 entre eux. Le partage doit donc être rare, ciblé et motivé — et le réseau privé par projet reste la règle.

- Le réseau privé par projet
- Partagé ou privé : comparaison
- Le réseau externe
- Choisir
- Ce que partager veut dire
- Le partage ciblé (RBAC)
- Adresses flottantes et exposition

Le réseau privé par projet

```
# Prérequis : jeton de portée projet, rôle member
export OS_PROJECT_NAME=prod-web OS_PROJECT_DOMAIN_NAME=nord

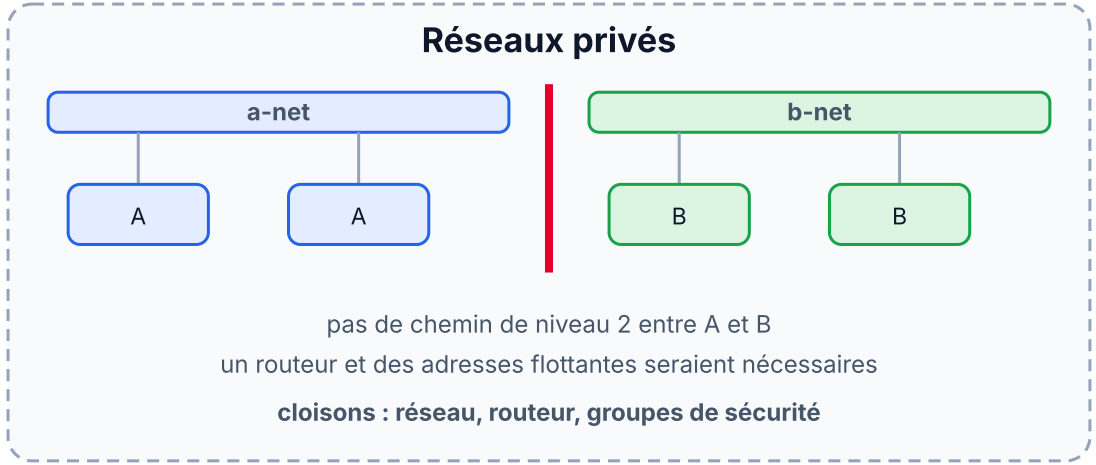
# Deux réseaux : façade et application
openstack network create prod-web-front
openstack subnet create prod-web-front-v4 \
  --network prod-web-front --subnet-range 10.10.1.0/24 \
  --dns-nameserver 10.0.0.53
openstack network create prod-web-app
openstack subnet create prod-web-app-v4 \
  --network prod-web-app --subnet-range 10.10.2.0/24 \
  --gateway none

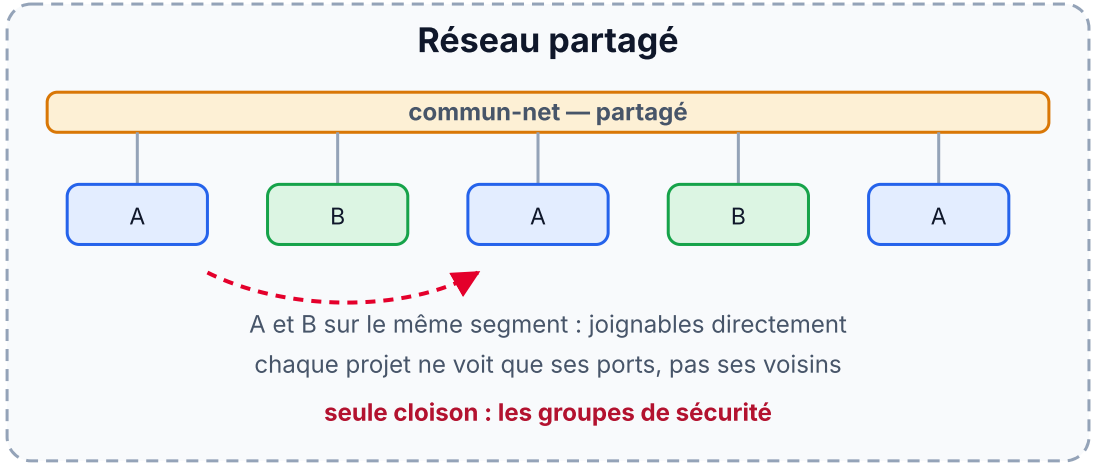
# Routeur : façade vers l'extérieur seulement
openstack router create prod-web-rtr
openstack router set prod-web-rtr \
  --external-gateway external-network
openstack router add subnet prod-web-rtr prod-web-front-v4
```

- **Un réseau par zone de sécurité de l'application,** pas un par machine : façade exposée, application, données.
- **Le réseau « app » n'a pas de passerelle** et n'est relié à aucun routeur : ses instances n'ont aucune route vers l'extérieur. Elles joignent la façade par des instances à deux interfaces, ou un répartiteur.
- **Le routeur** est le seul point de sortie : sans lui, le projet est hermétique.
- **Le nom du réseau externe** — ici `external-network` — est celui choisi à l'installation : `openstack network list --external`.

Décision	Effet de cloisonnement
Sous-réseau sans passerelle	aucune route sortante
Sous-réseau non relié au routeur	injoignable depuis les autres réseaux
Routeur sans passerelle externe	routage interne seulement
Quota d'adresses flottantes à 0	projet non exposable

Ce que partager un réseau veut dire





- **Sur un réseau partagé,** les instances de plusieurs projets sont sur le même segment de niveau 2. Elles se joignent directement, sans routeur — **seuls les groupes de sécurité les séparent.**
- **Chaque projet ne voit que ses propres ports,** mais il peut découvrir les autres adresses du segment par balayage.

- **Le groupe `default`** d'un projet n'autorise l'entrée que depuis ce même groupe — donc pas depuis les autres projets. C'est ce qui protège le cas général ; une seule règle trop large l'annule.
- **Usage légitime :** réseau d'administration ou de supervision, avec des règles d'entrée strictes du côté des instances.

Réseau partagé ou réseau privé : comparaison

Critère	Réseau privé par projet	Réseau partagé
Isolation de niveau 2	**oui : segment propre**	**non : segment commun**
Ce qui sépare les projets	**réseau, routeur, groupes de sécurité**	groupes de sécurité seuls
Plan d'adressage	**libre, recouvrement possible**	unique, géré par le propriétaire
Qui gère le sous-réseau	**le projet**	le propriétaire du réseau
Communication entre projets	**par adresses flottantes, contrôlée**	directe, sans traduction
Traçabilité des flux	**passages par routeur identifiables**	flux directs, plus difficiles à attribuer
Simplicité pour les équipes	**moindre : réseau et routeur à créer**	grande : on se branche
Recommandé pour	**applications, données, production**	services communs à accès strict

La simplicité du réseau partagé est un piège : c'est le choix par défaut des débutants, et la principale source de flux inattendus entre locataires.

Compromis courant : réseaux privés pour les applications, plus un réseau d'administration partagé par RBAC avec les seuls projets qui en ont besoin.

2 · PARTAGÉ OU PRIVÉ Vu au module 10

Le partage ciblé : RBAC de Neutron

Type d'objet	Ce que le partage permet
`network`	**créer des ports sur le réseau ; ou s'en servir comme réseau externe**
`security_group`	**appliquer le groupe à ses ports**
`address_group`	**utiliser le groupe d'adresses dans ses règles**
`qos_policy`	**appliquer la politique de qualité de service**
`subnetpool`, `address_scope`	**tirer des sous-réseaux d'un réservoir commun**

Action	Sens
`access_as_shared`	utilisation partagée
`access_as_external`	usage comme réseau externe : passerelle de routeur, adresses flottantes

```
# Partager le réseau d'administration avec UN projet
openstack network rbac create \
  --type network --action access_as_shared \
  --target-project prod-web --target-project-domain nord \
  admin-net

# Équivalent de --share : cible « * » (tous)
# — à éviter, et souvent réservé à l'administration
openstack network rbac create --type network \
  --action access_as_shared --target-all-projects admin-net

# Revue
openstack network rbac list --long
openstack network rbac delete <id>
```

- `--share` **à la création = cible « * » :** tous les projets, présents et futurs.
- **Retrait bloqué** tant que le projet cible a des ports sur le réseau : nettoyer d'abord.
- **Qui peut partager :** le propriétaire, avec un projet nommé ; la cible « * » est en principe réservée à l'administration — règle `create_rbac_policy` à resserrer si besoin.

2 · PARTAGÉ OU PRIVÉ

Le réseau externe

- **Un réseau de fournisseur marqué externe :** il correspond à un réseau physique de l'entreprise ou d'Internet, et porte les passerelles des routeurs et les adresses flottantes.
- **Par défaut, visible de tous les projets :** tout projet peut y raccorder un routeur et y prendre des adresses flottantes, dans la limite de ses quotas.
- **Plusieurs réseaux externes** permettent des niveaux d'exposition différents : un vers Internet, un vers le réseau interne de l'entreprise.
- **Réserver un réseau externe à certains projets :** le créer non partagé, puis l'ouvrir projet par projet avec `access_as_external`.

Sur Sunbeam, le réseau externe est déclaré par `sunbeam configure` ; d'autres réseaux de fournisseur s'ajoutent par l'API, sous réserve que le réseau physique correspondant soit raccordé aux hyperviseurs.

```
# Un second réseau externe, vers le SI interne,
# réservé aux projets qui en ont besoin (admin)
openstack network create externe-si \
  --external --no-share \
  --provider-network-type vlan \
  --provider-physical-network physnet1 \
  --provider-segment 120
openstack subnet create externe-si-v4 \
  --network externe-si --subnet-range 172.20.0.0/24 \
  --allocation-pool start=172.20.0.100,end=172.20.0.199 \
  --gateway 172.20.0.1 --no-dhcp

openstack network rbac create \
  --type network --action access_as_external \
  --target-project prod-web --target-project-domain nord \
  externe-si
```

Nom du réseau physique (`physnet1`) et identifiant de VLAN : selon le câblage et la configuration réseau de vos hyperviseurs.

2 · PARTAGÉ OU PRIVÉ Quotas : module 10

Adresses flottantes et exposition

Moyen d'exposition	Contrôle
Adresse flottante sur une instance	**quota `floating-ips` ; groupe de sécurité de l'instance**
Adresse flottante sur un répartiteur	**idem ; seul le répartiteur est exposé**
Redirection de port d'une adresse flottante	**un port d'une adresse vers un port d'une instance**
Port directement sur un réseau de fournisseur	**réservé à l'administration ou par RBAC**

- **Règle de conception :** une seule entrée par application — un répartiteur ou un bastion —, et aucune adresse flottante sur les serveurs d'application ou de données.
- **Mesure simple et efficace :** quota d'adresses flottantes à 0 sur les projets qui n'ont rien à exposer.

```
# Inventaire de l'exposition : toutes les adresses
# flottantes et ce à quoi elles sont associées
openstack floating ip list --long \
  -c "Floating IP Address" -c "Fixed IP Address" \
  -c Port -c Project

# Adresses réservées mais inutilisées : à rendre
openstack floating ip list --status DOWN

# Interdire l'exposition d'un projet
openstack quota set prod-bases --floating-ips 0
```

Chaque adresse flottante associée est une porte ouverte sur le cloud : l'inventaire de l'exposition se fait au moins chaque mois, et toute nouvelle association mérite une alerte (partie 5).

Choisir



Règle par défaut : réseau privé par projet. Tout partage est une exception documentée — qui, pourquoi, depuis quand — et revue comme une affectation de rôle.

03

Groupes de sécurité et micro-segmentation

La micro-segmentation consiste à n'autoriser, entre chaque composant, que les flux nécessaires — même à l'intérieur d'un réseau. Dans OpenStack, l'outil est le groupe de sécurité, appliqué port par port.

- Le groupe de sécurité
- Écrire des règles
- Une application à trois niveaux
- Sécurité de port
- Journaliser les flux
- Le groupe « default »
- Groupe distant ou adresse distante
- Groupes d'adresses, règles par défaut
- Mise en œuvre par OVN
- Cloisonnement inter-locataires : synthèse

Le groupe de sécurité

Propriété	Conséquence
Liste d'autorisations	**tout ce qui n'est pas autorisé est refusé ; aucune règle de refus**
Avec état	**la réponse à un flux autorisé est autorisée d'office**
Appliqué au port	**filtre au plus près de l'instance, même entre deux instances du même réseau**
Cumulatif	**plusieurs groupes sur un port = union des autorisations**
Dynamique	**une règle modifiée s'applique aux instances en cours**
Par projet	**chaque projet gère ses groupes ; partageables par RBAC**

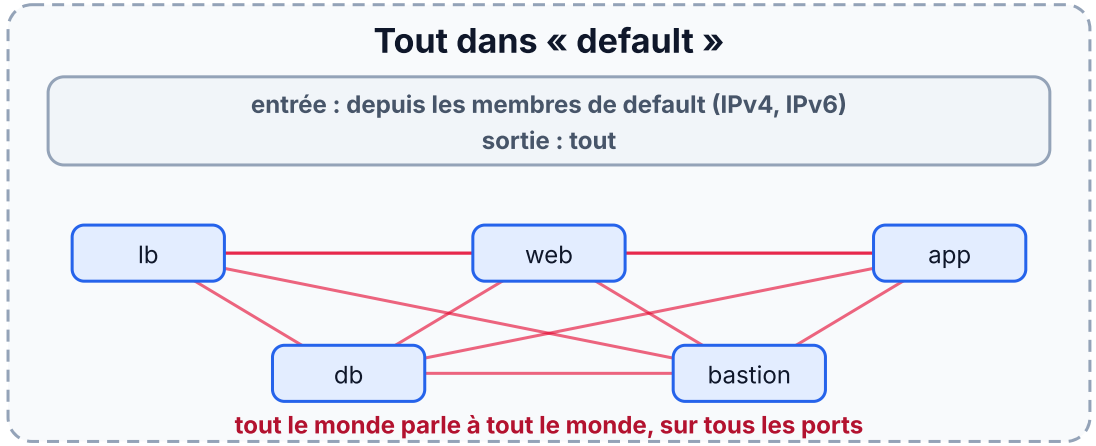
Sans état (`--stateless`) : les réponses doivent être autorisées explicitement. Réservé à des cas de performance particuliers.

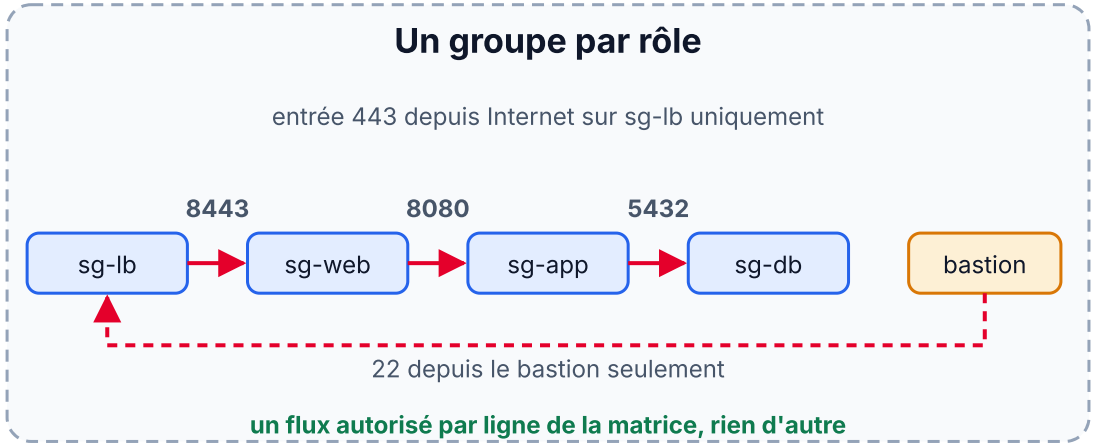
Une règle

Champ	Valeurs
Direction	entrée (`--ingress`) ou sortie (`--egress`)
Famille	IPv4 ou IPv6
Protocole	tcp, udp, icmp, numéro, ou tous
Ports	un port ou une plage
Origine ou destination	un bloc d'adresses, **ou** un groupe de sécurité, **ou** un groupe d'adresses

Pas de règle de refus : on ne peut pas écrire « tout sauf ce port ». Pour interdire, on retire l'autorisation. Les refus explicites relèvent du pare-feu de réseau (FWaaS) ou du pare-feu périmétrique.

Le groupe « default »





- **Créé automatiquement** dans chaque projet, et appliqué à toute instance créée sans groupe explicite.
- **Entrée :** uniquement depuis les membres du même groupe. **Sortie :** tout.
- **Conséquence :** toutes les instances d'un projet qui gardent `default` se parlent librement, sur tous les ports — l'inverse de la micro-segmentation.

- **Bonne pratique :** ne pas y ajouter de règles ; créer des groupes par rôle et les appliquer explicitement.
- **Sur le projet de démonstration Sunbeam,** il a été ouvert en SSH et ping depuis partout : ne pas s'en inspirer.
- **Il ne se supprime pas** tant que le projet existe ; on peut en revanche en retirer les règles.

Écrire des règles

```
# Prérequis : jeton de portée projet, rôle member

# Un groupe par rôle, vide au départ
openstack security group create sg-bastion \
  --description "Bastion d'administration"

# SSH vers le bastion, depuis le réseau d'administration
openstack security group rule create sg-bastion \
  --ingress --ethertype IPv4 --protocol tcp \
  --dst-port 22 --remote-ip 192.168.50.0/24 \
  --description "SSH depuis le réseau d'admin"

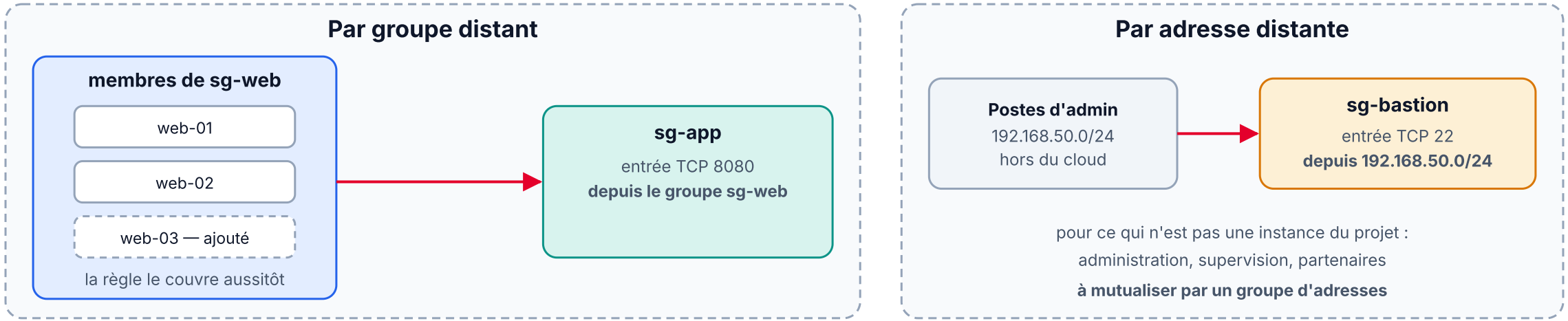
# Restreindre la sortie (règles de sortie par défaut
# à retirer d'abord)
openstack security group rule list sg-bastion --egress
openstack security group rule delete <id-sortie-v4> <id-sortie-v6>
openstack security group rule create sg-bastion \
  --egress --protocol tcp --dst-port 22 \
  --remote-ip 10.10.0.0/16

# Appliquer à une instance, retirer default
openstack server add security group bastion-01 sg-bastion
openstack server remove security group bastion-01 default
```

- **Tout nouveau groupe** contient deux règles de sortie vers tout — IPv4 et IPv6 — et aucune d'entrée.
- **Filtrer la sortie** limite l'exfiltration et les rebonds depuis une instance compromise : utile pour les serveurs de données et les bastions.
- **Une description par règle :** qui l'a demandée, pour quel flux. Six mois plus tard, c'est la seule documentation qui reste.
- **Éviter `0.0.0.0/0` en entrée,** sauf pour un service public derrière un répartiteur.

Règle à proscrire	Pourquoi
tout protocole, entrée, `0.0.0.0/0`	supprime tout filtrage
SSH ou RDP depuis `0.0.0.0/0`	exposition à Internet de l'administration
port de base de données depuis un réseau entier	accès direct aux données

Groupe distant ou adresse distante



- **Par groupe distant :** « autoriser le port 8080 depuis les membres de `sg-web` ». La règle suit les instances : ajouter un serveur web au groupe lui ouvre le flux, sans toucher aux règles.
- **C'est la base de la micro-segmentation :** on raisonne en rôles, pas en adresses.
- **Par adresse distante :** pour ce qui n'est pas une instance du projet — réseau d'administration, sonde de supervision, partenaire.
- **Limite du groupe distant :** il ne voit que les adresses fixes des ports ; un flux qui passe par une adresse flottante ou un routeur arrive avec une autre adresse source.

Une application à trois niveaux : la matrice de flux

Source	Destination	Flux	Règle (sur le groupe destination)	Justification
Internet	`sg-lb`	TCP 443	entrée 443 depuis `0.0.0.0/0`	seul point exposé
`sg-lb`	`sg-web`	TCP 8443	entrée 8443 depuis groupe `sg-lb`	le répartiteur seul parle aux serveurs web
`sg-web`	`sg-app`	TCP 8080	entrée 8080 depuis groupe `sg-web`	appel de l'API métier
`sg-app`	`sg-db`	TCP 5432	entrée 5432 depuis groupe `sg-app`	seule l'application touche aux données
`sg-bastion`	**tous**	TCP 22	entrée 22 depuis groupe `sg-bastion`, sur chaque groupe	administration par rebond
supervision	**tous**	TCP 9100	entrée 9100 depuis l'adresse de la sonde	métriques
`sg-db`	**extérieur**	aucun	sortie limitée au réseau du projet	pas d'exfiltration directe

Méthode

Lister les flux nécessaires avant d'écrire une règle ; chaque ligne de la matrice devient une règle, et réciproquement.

Ce qui n'y figure pas

Serveur web vers base de données, Internet vers l'application, bastion vers Internet : ces flux sont refusés sans rien écrire.

Un seul réseau suffit

Les quatre niveaux peuvent partager un réseau : les groupes séparent. Des réseaux distincts ajoutent une seconde barrière.

Pas à pas : les groupes de l'application

```
# Prérequis : projet prod-web, rôle member
for g in sg-lb sg-web sg-app sg-db sg-bastion; do
  openstack security group create $g
done

R="openstack security group rule create"
$R sg-lb  --ingress --protocol tcp --dst-port 443 \
   --remote-ip 0.0.0.0/0 --description "HTTPS public"
$R sg-web --ingress --protocol tcp --dst-port 8443 \
   --remote-group sg-lb  --description "LB vers web"
$R sg-app --ingress --protocol tcp --dst-port 8080 \
   --remote-group sg-web --description "web vers app"
$R sg-db  --ingress --protocol tcp --dst-port 5432 \
   --remote-group sg-app --description "app vers base"
$R sg-bastion --ingress --protocol tcp --dst-port 22 \
   --remote-ip 192.168.50.0/24 --description "admin"
for g in sg-web sg-app sg-db; do
  $R $g --ingress --protocol tcp --dst-port 22 \
     --remote-group sg-bastion --description "rebond SSH"
done
# sg-db : sortie limitée au réseau du projet (matrice)
for r in $(openstack security group rule list sg-db \
           --egress -f value -c ID); do
  openstack security group rule delete $r
done
$R sg-db --egress --remote-ip 10.10.0.0/16 --description "sortie interne"
```

```
# Créer les instances avec leur seul groupe
openstack server create db-01 --flavor m1.medium \
  --image ubuntu-24.04 --network prod-web-app \
  --security-group sg-db --key-name exploitation

# Vérifier les groupes effectifs d'un port
openstack port list --server db-01 -c ID -c "Fixed IP Addresses"
openstack port show <port> -c security_group_ids
```

Test de cloison	Attendu
web-01 → db-01:5432	**refusé**
app-01 → db-01:5432	**accepté**
app-01 → db-01:22	**refusé**
bastion → db-01:22	**accepté**
Internet → web-01:8443	**refusé**

> Tester avec `nc -zv -w 3 <ip> <port>` depuis chaque instance : un refus par groupe de sécurité se traduit par un délai dépassé, pas par un refus de connexion.

Groupes d'adresses

Problème : la même liste d'adresses — réseau d'administration, sondes de supervision, partenaires — revient dans des dizaines de règles. La modifier impose de toutes les retrouver.

Solution : un groupe d'adresses, nommé, référencé par les règles. On modifie le groupe ; toutes les règles suivent.

```
# Le groupe : les réseaux d'administration
openstack address group create ag-admin \
  --address 192.168.50.0/24 --address 192.168.51.0/24 \
  --description "Postes d'administration"

# Les règles le référencent
openstack security group rule create sg-bastion \
  --ingress --protocol tcp --dst-port 22 \
  --remote-address-group ag-admin

# Un nouveau site d'administration : une commande
openstack address group set ag-admin --address 192.168.52.0/24
```

Groupe d'adresses type	Contenu
`ag-admin`	**postes et bastions d'administration**
`ag-supervision`	**collecteurs de métriques et de journaux**
`ag-partenaire-x`	**adresses publiques d'un partenaire**
`ag-sauvegarde`	**serveurs de sauvegarde**

- **Partageables par RBAC :** l'équipe plateforme publie `ag-admin` ; chaque projet l'utilise sans le modifier.
- **Prise en charge** par le pilote OVN : à vérifier sur votre version, par un essai.

> Un groupe d'adresses partagé par la plateforme garantit qu'un changement d'adressage de l'administration se propage dans tous les projets, le jour même.

Règles par défaut des nouveaux groupes

Depuis 2023.2, l'administration peut définir les règles que Neutron place dans les nouveaux groupes : groupes `default` des projets, et groupes créés par les utilisateurs.

```
# Prérequis : identifiants d'administrateur
openstack default security group rule list

# Supervision autorisée dans tous les futurs groupes
openstack default security group rule create \
  --ingress --protocol tcp --dst-port 9100 \
  --remote-address-group ag-supervision \
  --for-default-sg --for-custom-sg \
  --description "Métriques, plateforme"

# Supprimer un modèle de règle
openstack default security group rule delete <id>
```

Option	S'applique à
`--for-default-sg`	groupes `default` créés automatiquement
`--for-custom-sg`	groupes créés par les utilisateurs

- **Seulement pour les groupes futurs :** supprimer ou ajouter un modèle ne modifie pas les groupes existants.
- **Usage utile :** retirer la sortie libre des nouveaux groupes, ou ajouter les flux de la plateforme — supervision, sauvegarde — partout.
- **À manier avec prudence :** une règle trop large ajoutée ici se retrouve dans tous les projets.

> Référencer un groupe d'adresses dans un modèle suppose qu'il soit partagé avec tous les projets ; sinon, utiliser un bloc d'adresses.

Sécurité de port et paires d'adresses autorisées

Mécanisme	Effet
Sécurité de port activée (défaut)	**le port n'émet qu'avec son adresse MAC et ses adresses IP ; groupes de sécurité appliqués**
Sécurité de port désactivée	**aucune protection contre l'usurpation d'adresse, aucun groupe de sécurité**
Paires d'adresses autorisées	**adresses supplémentaires qu'un port peut utiliser — adresse virtuelle partagée par deux instances**

Désactiver la sécurité de port retire toute micro-segmentation pour ce port et lui permet d'usurper l'adresse d'un voisin. À n'accepter que pour des appliances réseau — routeur virtuel, pare-feu — dans un réseau dédié.

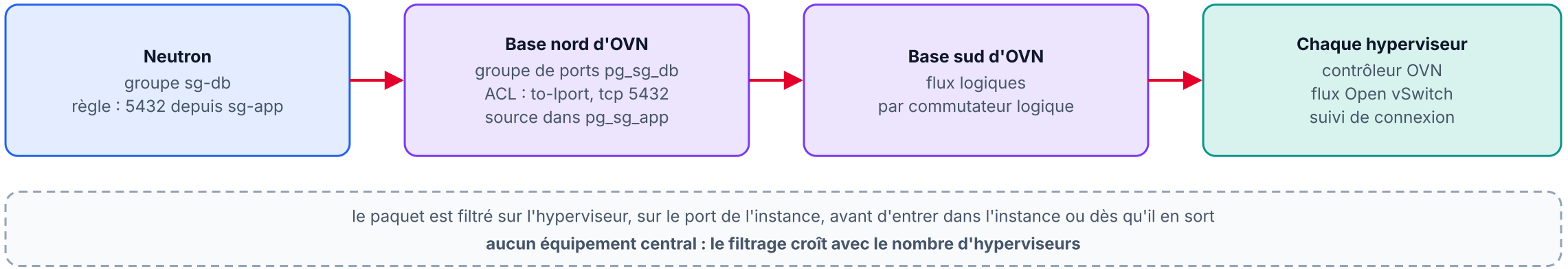
```
# Adresse virtuelle partagée par deux répartiteurs
# (keepalived), sans désactiver la sécurité de port
openstack port set <port-lb-01> \
  --allowed-address ip-address=10.10.1.250
openstack port set <port-lb-02> \
  --allowed-address ip-address=10.10.1.250

# Repérer les ports sans sécurité de port
openstack port list --long -f json \
  | jq -r '.[] | select(.["Port Security"]==false) | .ID'
# (nom de colonne selon le client ; sinon port show)

# Rétablir
openstack port set <port> --enable-port-security \
  --security-group sg-web
```

Les paires d'adresses autorisées sont la bonne réponse à « j'ai besoin d'une adresse virtuelle » ; la désactivation de la sécurité de port ne l'est presque jamais.

Mise en œuvre par OVN



- **Un groupe de sécurité devient un groupe de ports OVN** et ses règles des ACL, inscrites dans la base nord puis traduites pour chaque hyperviseur.
- **Le filtrage se fait dans Open vSwitch** sur l'hyperviseur de l'instance, avec suivi de connexion : il n'y a pas de pare-feu central à saturer.
- **Une instance compromise ne peut pas contourner ses règles :** elles s'appliquent hors de l'instance, sur le port.
- **Lire ce qu'OVN a reçu :** `ovn-nbctl acl-list` dans le conteneur de la base nord — réservé au diagnostic, jamais pour modifier.

Groupes de sécurité, pare-feu de réseau, pare-feu périmétrique

Critère	Groupes de sécurité	Pare-feu de réseau (FWaaS v2)	Pare-feu périmétrique
Point d'application	**chaque port d'instance**	ports de routeur	sortie physique du cloud
Règles de refus	**non**	**oui**	**oui**
Ordre des règles	**sans objet : union**	ordonnées	ordonnées
Géré par	**le projet**	le projet	l'équipe réseau
Trafic interne à un réseau	**filtré**	**non vu**	**non vu**
Inspection applicative	**non**	**non**	selon le produit
Sur Sunbeam	**disponible**	OVN le prend en charge ; disponibilité dans Sunbeam à vérifier	hors du cloud

Défense en profondeur : le pare-feu périmétrique filtre l'entrée du cloud ; les groupes de sécurité filtrent entre composants. L'un ne remplace pas l'autre.

Pour ce module, les groupes de sécurité suffisent à la micro-segmentation ; le pare-feu de réseau ne s'ajoute que si l'on a besoin de règles de refus ordonnées entre sous-réseaux.

Journaliser les flux des groupes de sécurité

```
# Prérequis : extension « log » de Neutron active
openstack extension list --network | grep -i logging

# Journaliser les flux acceptés et refusés d'un groupe
openstack network log create log-sg-db \
  --resource-type security_group --resource sg-db \
  --event ALL

# Seulement les refus (attention : avec OVN, les refus
# de tous les groupes sont agrégés)
openstack network log create log-drop \
  --resource-type security_group --event DROP

openstack network log list
openstack network log set --disable log-sg-db
```

Exemple de ligne, dans le journal du contrôleur OVN de l'hyperviseur :

```
 name="neutron-e9eb…", verdict=allow, severity=info,
direction=to-lport, tcp, nw_src=10.10.2.15, nw_dst=10.10.3.20,
tp_dst=5432
```

Point	Détail
Où sont les lignes	journal du contrôleur OVN de chaque hyperviseur : chacun ne voit que ses instances
Débit	limité par `[network_log] rate_limit` et `burst_limit` — au moins 100 et 25
Cible par port	non disponible avec OVN
Refus	une ACL agrège tous les refus : journaliser DROP les capture tous
Volume	sans `--resource`, tout le cloud : volume considérable

Sur Sunbeam : l'activation du greffon de journalisation dans Neutron et l'acheminement du journal du contrôleur OVN vers la centralisation sont à vérifier sur votre déploiement avant de compter sur cette source.

Cloisonnement inter-locataires : synthèse et contrôles

Couche	Ce qui cloisonne	Ce qui le défait	Contrôle périodique
Identité	**projets, rôles, domaines**	rôle sur plusieurs projets, `admin`	`role assignment list --effective`
Niveau 2	**réseau privé par projet, Geneve**	réseau partagé	`network rbac list` ; réseaux `Shared`
Niveau 3	**routeur propre, pas de route commune**	routeur relié aux sous-réseaux de deux projets	`router list --long` , interfaces
Exposition	**pas d'adresse flottante**	adresses flottantes inutiles	`floating ip list --long`
Port	**groupes de sécurité par rôle**	`0.0.0.0/0` en entrée, `default` élargi	règles larges, voir slide 9
Anti-usurpation	**sécurité de port**	sécurité de port désactivée	ports sans sécurité de port
Ressources	**quotas**	quotas illimités	`quota show --usage`

Test de cloison entre locataires, après chaque changement : depuis une instance du projet A, tenter de joindre l'adresse fixe et l'adresse flottante d'une instance du projet B, sur un port non autorisé. Attendu : échec dans les deux cas.

Ces contrôles s'automatisent en un script lancé chaque semaine, dont le résultat part dans les journaux centralisés — ce qui fait la transition avec la suite.

04

Audit et traçabilité : la journalisation des services

Un cloud produit des journaux partout : chaque service, chaque nœud, chaque hyperviseur. Pour l'audit, il ne suffit pas qu'ils existent ; il faut savoir où ils sont, ce qu'ils contiennent, et comment relier entre elles les lignes d'une même action.

- Les questions de l'audit
- Anatomie d'une ligne
- Les événements d'instance
- Le filtre d'audit des API
- Les sources de journaux
- Les identifiants de requête
- Les notifications CADF de Keystone
- Niveaux et données sensibles

4 · JOURNALISATION

Les questions de l'audit

Qui ?
Utilisateur, projet, domaine ; compte de service ; identifiant d'application.

Quoi ?
L'opération : création d'instance, ajout de rôle, règle de sécurité.

Sur quoi ?
La ressource visée, par son identifiant.

Quand, d'où ?
Horodatage synchronisé ; adresse source de la requête.

Avec quel résultat ?
Succès, refus (401, 403), erreur.

Question type d'enquête	Source qui y répond
Qui a supprimé l'instance `db-01` ?	événements d'instance de Nova ; journal de l'API de Nova
Qui a donné le rôle `admin` à ce compte ?	notifications CADF de Keystone ; journal de Keystone
Qui a ouvert le port 22 à tout Internet ?	journal de l'API de Neutron, par identifiant de requête
Combien d'échecs de connexion cette nuit, depuis où ?	journal de Keystone ; autorité fédérée
Cette instance a-t-elle parlé à la base ?	journal des groupes de sécurité, s'il est activé

Ces cinq questions sont celles du format d'événement d'audit CADF, qu'OpenStack utilise : initiateur, action, cible, horodatage et observateur, résultat.

Les sources de journaux d'un cloud Sunbeam

Source	Où elle tourne	Ce qu'elle trace	Lire localement
API des services : Keystone, Nova, Neutron, Cinder, Glance…	**pods Kubernetes, modèle Juju** `openstack`	requêtes, utilisateur, projet, code de retour	`sudo k8s kubectl -n openstack logs <pod> -c <conteneur>`
Services de calcul et réseau des hyperviseurs	**snap** `openstack-hypervisor`	démarrage d'instances, contrôleur OVN, libvirt	`sudo snap logs openstack-hypervisor`, journal système
Charms	**agents Juju**	changements de configuration, actions	`juju debug-log -m openstack`
Horizon	**pod**	connexions au tableau de bord	journaux du pod
Base de données, messagerie	**pods MySQL, RabbitMQ**	erreurs, connexions	journaux des pods
Vault	**pod**	accès aux secrets, certificats	journal d'audit de Vault, s'il est activé
Systèmes des nœuds	**Ubuntu**	connexions SSH, sudo, noyau	`journalctl`, `/var/log/auth.log`
Autorité fédérée	**hors du cloud**	authentifications, multifacteur	console de l'autorité

Les journaux d'un pod sont éphémères : un redémarrage ou un remplacement du pod les fait disparaître. Sans centralisation, une enquête sur un incident de la semaine passée est souvent impossible.

Chemins et noms de conteneurs à vérifier sur votre version de Sunbeam ; la partie 5 évite d'avoir à les connaître en centralisant tout.

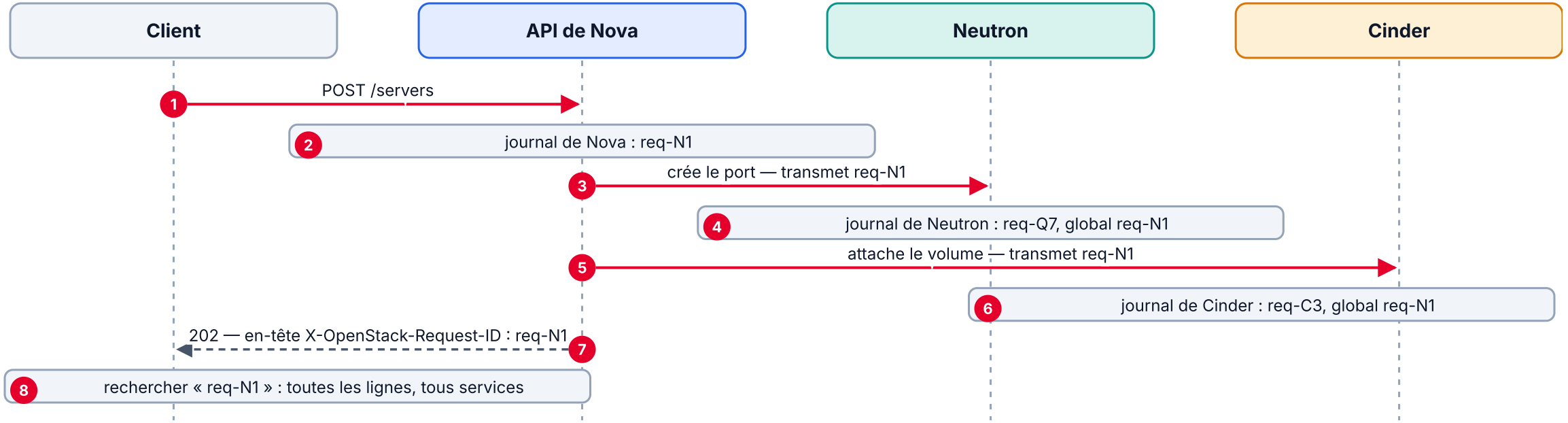
Anatomie d'une ligne de journal

```
2026-10-13 09:42:17.512 12 INFO nova.osapi_compute.wsgi.server
  [req-0b9f…  req-7c1e…  4f2a…(utilisateur)  9d81…(projet)  -  default  default]
  10.20.0.15 "DELETE /v2.1/servers/5e3b…  HTTP/1.1" status: 204 len: 0 time: 0.2134
```

Élément	Sens	Usage en enquête
Horodatage	**heure du nœud qui écrit**	ordonner — à condition que les horloges soient synchronisées
Niveau, module	**INFO, WARNING, ERROR ; composant**	filtrer
1er `req-…`	**identifiant global, transmis d'un service à l'autre**	suivre une action à travers les services
2e `req-…`	**identifiant de la requête dans ce service**	retrouver toutes les lignes de cette requête
Utilisateur, projet, domaines	**identité extraite du jeton**	qui, pour quel projet
Adresse, requête, statut, durée	**ligne d'accès de l'API**	d'où, quoi, résultat

> Format indicatif, reconstitué : l'ordre et la présence des champs dépendent du service et de sa configuration de journalisation (`logging_context_format_string`).

Les identifiants de requête



- **Chaque service** attribue un identifiant `req-…` à chaque requête reçue et le renvoie dans l'en-tête de réponse `X-OpenStack-Request-ID`.
- **Lorsqu'un service en appelle un autre,** il transmet l'identifiant d'origine : le service appelé l'inscrit comme identifiant global à côté du sien.
- **Le client peut fournir son propre identifiant** global ; un outil d'automatisation l'utilise pour relier ses actions aux journaux du cloud.
- **En pratique :** on part de l'identifiant renvoyé à l'utilisateur ou affiché par `openstack --debug`, puis on cherche cette chaîne dans tous les journaux centralisés.

Les événements d'instance

```
# Historique des actions sur une instance
openstack server event list db-01

+------------------+--------------+--------+---------------------+
| Request ID       | Server ID    | Action | Start Time          |
+------------------+--------------+--------+---------------------+
| req-7c1e…        | 5e3b…        | delete | 2026-10-13T09:42:17 |
| req-31aa…        | 5e3b…        | reboot | 2026-10-12T22:05:03 |
| req-f02c…        | 5e3b…        | create | 2026-10-01T08:11:46 |
+------------------+--------------+--------+---------------------+

# Détail : qui, depuis quel projet, résultat
openstack server event show db-01 req-7c1e…

# Instance déjà supprimée : par identifiant,
# avec les droits d'administration
openstack server event list 5e3b…
```

> Sortie reconstituée pour l'exemple ; les colonnes dépendent de la microversion de l'API de Nova.

Champ	Usage
Action	**création, arrêt, redémarrage, migration, suppression…**
Identifiant de requête	**pivot vers les journaux de tous les services**
Utilisateur, projet	**auteur de l'action**
Étapes, résultat	**succès ou erreur de chaque étape interne**

- **Première source à consulter** pour toute question sur une instance : elle est dans la base de Nova, donc survit aux redémarrages des pods.
- **Limites :** elle ne couvre que les instances. Pour les réseaux, les volumes, les rôles, il faut les journaux des autres services.
- **Les membres du projet** voient les événements de leurs instances ; utile au support de premier niveau.

Les notifications CADF de Keystone

```
{
  "event_type": "identity.role_assignment.created",
  "priority": "INFO",
  "publisher_id": "identity.keystone-0",
  "payload": {
    "typeURI": "http://schemas.dmtf.org/cloud/audit/1.0/event",
    "eventType": "activity",
    "eventTime": "2026-10-13T09:58:02.114+0000",
    "action": "created.role_assignment",
    "outcome": "success",
    "initiator": {
      "id": "4f2a…",
      "host": { "address": "10.20.0.15",
                "agent": "openstacksdk/4.x" }
    },
    "target": { "typeURI": "…/role_assignment", "id": "…" },
    "observer": { "typeURI": "service/security", "id": "…" },
    "role": "…", "user": "…", "project": "…"
  }
}
```

Réglage de Keystone	Effet
`notification_format = cadf`	**événements au format d'audit CADF, plutôt que le format simple**
`notification_opt_out`	**liste des événements à ne pas émettre ; par défaut, les authentifications réussies ou échouées sont supprimées**
Pilote de notifications	**messagerie (vers un consommateur) ou journal**

- **Événements émis :** création, modification, suppression des utilisateurs, groupes, projets, domaines, rôles, affectations, points d'accès ; authentifications si on les réactive.
- **Pour l'audit,** réactiver les échecs d'authentification : c'est la trace d'une attaque par essais.

Sur Sunbeam : le charm de Keystone propose l'option `enable-telemetry-notifications`, liée à la fonctionnalité de télémétrie. Format et destination des notifications sont à vérifier sur votre déploiement avant d'en faire une source d'audit.

4 · JOURNALISATION

Le filtre d'audit des API

Un filtre de keystonemiddleware, placé dans la chaîne de traitement d'un service, produit un événement CADF pour chaque appel de son API : initiateur, action, cible, résultat.

```
# api-paste.ini du service (exemple de Nova)
[filter:audit]
paste.filter_factory = keystonemiddleware.audit:filter_factory
audit_map_file = /etc/nova/api_audit_map.conf
# ignorer les lectures, trop volumineuses
ignore_req_list = GET,HEAD

# Placé APRÈS authtoken dans la chaîne
keystone = … authtoken keystonecontext … audit osapi_compute_app_v21

# nova.conf : où envoyer les événements
[audit_middleware_notifications]
driver = log
```

Source d'audit	Couverture
Ligne d'accès de l'API	toutes les requêtes, format libre
Événements d'instance	instances seulement, structuré
Notifications de Keystone	identité seulement, CADF
Filtre d'audit des API	toutes les API équipées, CADF

- **Le plus complet** des mécanismes, et le plus volumineux : n'auditer que les écritures.
- **Sans messagerie configurée,** les événements partent dans le journal du service — ce qui suffit si ce journal est centralisé.

Sur Sunbeam, la chaîne de traitement des API est écrite par les charms : le filtre d'audit n'est pas activable à la main de façon durable. Les lignes d'accès et les événements d'instance restent les sources disponibles.

Niveaux de journalisation et données sensibles

Niveau	Contenu	Usage
ERROR	**échecs**	toujours
WARNING	**anomalies, refus d'authentification**	par défaut des charms
INFO	**requêtes de l'API, actions**	nécessaire à l'audit
DEBUG	**détails internes, attributs reçus**	diagnostic ponctuel

```
# Niveau de journalisation d'un service Sunbeam
juju config -m openstack keystone log-level
juju config -m openstack nova log-level=INFO
# (option à vérifier pour chaque charm)
```

- **Le niveau WARNING par défaut** ne garde pas les lignes d'accès de l'API : l'audit des actions réussies demande au moins INFO sur les services d'API.
- **Les jetons et mots de passe sont masqués** par les bibliothèques d'OpenStack dans les journaux ; le niveau DEBUG peut néanmoins exposer des attributs personnels — fédération, données utilisateur.
- **Les journaux contiennent des données personnelles :** identifiants, adresses IP. Leur conservation et leur accès relèvent du RGPD — la CNIL a publié une recommandation sur ce point.
- **Le volume** croît vite au niveau INFO : dimensionner le stockage de la centralisation en conséquence.

> Passer en DEBUG pour un diagnostic, c'est ouvrir une fenêtre de données sensibles : en noter le début, la fin, et revenir au niveau normal le jour même.

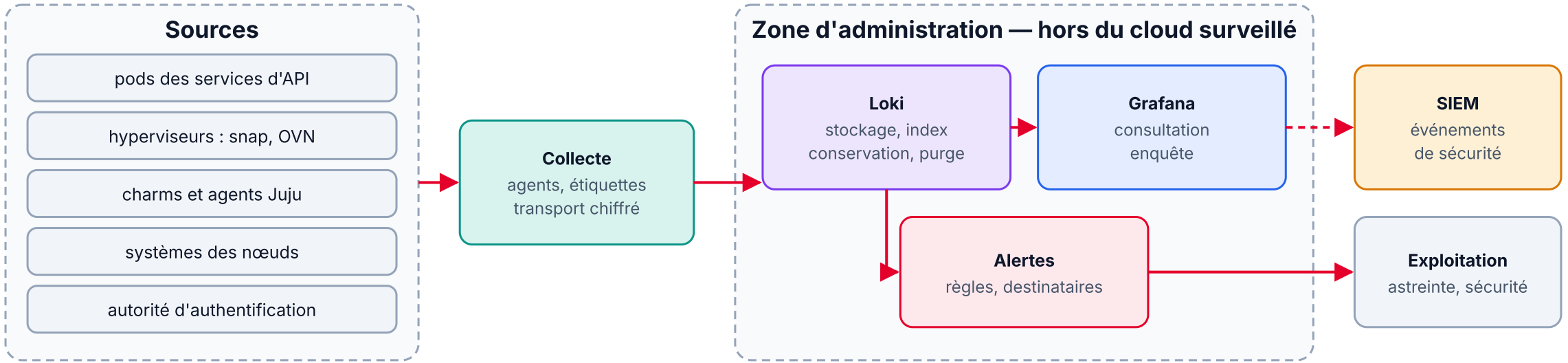
05

Corrélation et centralisation des journaux

Un journal resté sur la machine qui l'a produit disparaît avec elle, et peut être effacé par qui la compromet. Centraliser, c'est le mettre hors de portée, le conserver, et pouvoir enfin relier les événements de toutes les sources.

- Architecture de centralisation
- L'observabilité de Sunbeam
- Une enquête pas à pas
- Vers un SIEM
- Ce que recommandent l'ANSSI et la CNIL
- Interroger les journaux
- Règles d'alerte
- Protéger la chaîne

Architecture de centralisation



- **Collecte au plus près :** un agent par nœud ou par modèle lit les journaux et les envoie, étiquetés par origine.
- **Stockage hors des systèmes surveillés :** les journaux échappent à un administrateur ou un attaquant présent sur un nœud du cloud.
- **Exploitation à deux usages :** consultation et enquête d'un côté, alertes de l'autre.
- **Le SIEM de l'entreprise,** s'il existe, reçoit une copie des événements de sécurité pour les corréler avec le reste du système d'information.

Ce que recommandent l'ANSSI et la CNIL

ANSSI — *Recommandations de sécurité pour l'architecture d'un système de journalisation* (31 recommandations)

Thème	Idée principale
Horodatage	**synchroniser toutes les sources sur une même référence de temps**
Centralisation	**exporter vers un système distinct de celui qui produit les journaux**
Zone de confiance	**le serveur de collecte est une cible : le placer dans la zone d'administration, isolé**
Transport	**choisir le mode — temps réel ou différé — et chiffrer le transfert**
Stockage	**dimensionner, surveiller, protéger contre lecture, modification et suppression**
Santé de la chaîne	**vérifier régulièrement que les journaux arrivent, complets**
Événements	**authentification, gestion des comptes, politique de sécurité — annexe du guide**

CNIL — recommandation relative aux mesures de journalisation (2021)

Thème	Recommandation
Conservation	**entre six mois et un an en règle générale ; au-delà, justification documentée**
Séparation	**stocker à part, sur un équipement où les applications écrivent sans pouvoir réécrire**
Accès	**habilitations spécifiques, limitées au strict nécessaire**
Analyse	**analyse en temps réel ou à court terme, processus d'alerte formalisé**
Intégrité	**horodater et signer dès la création**
Finalité	**usage de sécurité seulement ; informer les utilisateurs**

> La recommandation de la CNIL vise les journaux applicatifs de traitements de données personnelles ; ses durées sont un bon point de départ pour ceux d'un cloud, à confirmer avec le délégué à la protection des données.

5 · CENTRALISATION

L'observabilité de Sunbeam

```
# Option 1 — pile d'observabilité intégrée au cloud
sunbeam enable observability embedded

# Option 2 — pile existante, sur un autre contrôleur Juju
# (contrôleur enregistré, droits de consommation des offres)
sunbeam enable observability external \
  cos-controller \
  <offre-grafana-dashboard> \
  <offre-prometheus-receive-remote-write> \
  <offre-loki-logging>

# Adresse de Grafana et mot de passe initial
sunbeam observability dashboard-url
juju run --model observability grafana/leader \
  get-admin-password
```

Taille du stockage de la pile intégrée : fixée dans le fichier manifeste au déploiement ; la modifier ensuite n'est pas pris en charge. À dimensionner dès le départ.

Composant	Rôle
Loki	**stockage et requête des journaux**
Prometheus	**métriques : services, hyperviseurs, capacité**
Grafana	**tableaux de bord, consultation, alertes**

Tableau de bord fourni	Usage
OpenStack Logging	journaux des services, codes HTTP des API
OpenStack Service Overview	état des services
OpenStack Project Overview	consommation par projet
Capacity	projection de la capacité

Pile externe recommandée pour l'audit : les journaux sortent du cloud qu'ils décrivent, comme le demande l'ANSSI.

Interroger les journaux

```
# Requêtes LogQL, dans Grafana > Explore > Loki
# (étiquettes Juju indicatives : juju_model,
#  juju_application, juju_unit)

# Toutes les lignes d'une requête, tous services
{juju_model="openstack"} |= "req-7c1e"

# Suppressions d'instances
{juju_application="nova"} |= "DELETE /v2.1/servers"

# Échecs d'authentification dans Keystone
{juju_application="keystone"} |= "Authorization failed"

# Ajouts de règles de groupe de sécurité
{juju_application="neutron"} |= "POST /v2.0/security-group-rules"

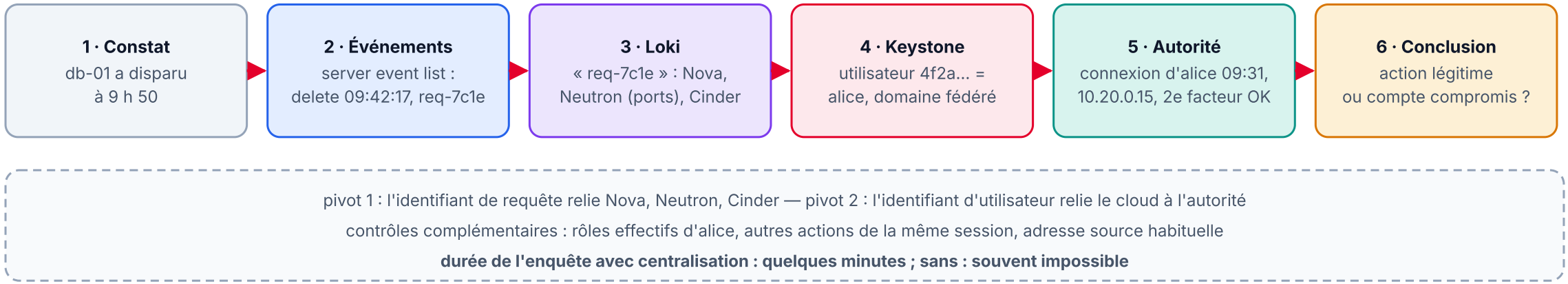
# Nombre de refus 403 par service, sur 5 minutes
sum by (juju_application) (
  count_over_time({juju_model="openstack"} |= "status: 403" [5m]))
```

Élément LogQL	Rôle
`{…}`	**sélection des flux par étiquettes : modèle, application, unité**
`|=` , `!=`	**contient, ne contient pas**
`|~`	**expression régulière**
`count_over_time`	**compter sur une fenêtre : base des alertes**

- **Commencer large, filtrer ensuite :** un identifiant de requête suffit à retrouver toute une action.
- **Les étiquettes** disponibles se lisent dans Grafana : explorer le sélecteur avant d'écrire une requête.
- **Chaînes de recherche** à adapter au format réel de vos journaux — vérifier sur une ligne connue.

> Ces requêtes, enregistrées comme tableaux de bord, deviennent le poste de travail de l'enquête.

Une enquête pas à pas : qui a supprimé la base ?



La corrélation tient en deux pivots : l'identifiant de requête relie les services entre eux ; l'identifiant d'utilisateur relie le cloud à l'autorité d'authentification.

Ce qui la rend possible : horloges synchronisées, niveau INFO sur les API, journaux centralisés et conservés, événements d'authentification réactivés.

5 · CENTRALISATION

Règles d'alerte utiles

Événement	Pourquoi	Source	Seuil indicatif
Échecs d'authentification répétés sur un compte	**attaque par essais, compte verrouillé**	Keystone	> 10 en 5 minutes
Échec d'authentification d'un compte de service	**secret changé, attaque, panne imminente**	Keystone	dès le premier
Affectation du rôle `admin`	**élévation de privilège**	Keystone	chaque occurrence
Règle d'entrée depuis `0.0.0.0/0` hors port 443	**exposition non voulue**	Neutron	chaque occurrence
Création d'une politique RBAC réseau	**ouverture entre locataires**	Neutron	chaque occurrence
Association d'une adresse flottante	**nouvelle exposition**	Neutron	revue quotidienne
Sécurité de port désactivée	**perte d'anti-usurpation**	Neutron	chaque occurrence
Suppressions en masse	**erreur ou sabotage**	Nova, Cinder	> 20 en 10 minutes
Connexion du compte de secours	**usage exceptionnel**	Keystone	chaque occurrence
Source de journaux muette	**chaîne de collecte cassée**	Loki	aucune ligne depuis 15 minutes

Une alerte doit appeler une action : chacune a un destinataire et une procédure. Une alerte que personne ne traite sera ignorée avec les autres.

La dernière ligne est la plus importante : sans elle, une chaîne de collecte cassée passe inaperçue jusqu'au jour de l'enquête.

5 · CENTRALISATION

Vers le SIEM de l'entreprise

Voie	Principe et remarque
Depuis Loki	**le SIEM interroge Loki, ou un exportateur pousse une sélection d'événements**
Agent de collecte en double envoi	**les mêmes journaux partent vers Loki et vers le SIEM**
Journal système des nœuds	**transfert syslog chiffré depuis chaque nœud**
Notifications CADF	**consommateur de la messagerie qui les relaie au SIEM**

- **N'envoyer au SIEM que la sécurité :** authentifications, changements de droits, de règles réseau, d'exposition ; pas les journaux de fonctionnement.
- **Normaliser :** le SIEM attend des champs — utilisateur, source, action, résultat — ; CADF les fournit déjà, les lignes d'accès demandent une analyse.

Ce que le SIEM apporte

- la corrélation avec le reste du SI : poste de travail, autorité, pare-feu ;
- la conservation longue, à part ;
- une équipe de détection qui surveille déjà.

Ce qu'il ne remplace pas

- les tableaux de bord d'exploitation du cloud ;
- la connaissance des identifiants de requête et des événements d'instance pour enquêter.

Le choix de la voie dépend du SIEM en place et de son mode de collecte : à concevoir avec son équipe, en commençant par la liste des événements de la slide précédente.

5 · CENTRALISATION

Protéger la chaîne de journalisation

Exigence	Risque si absente	Mesure
Horodatage commun	**événements impossibles à ordonner**	NTP sur tous les nœuds, l'autorité, la pile de journalisation ; supervision du décalage
Transport chiffré	**lecture ou falsification en transit**	TLS entre agents et Loki ; relations Juju sur réseau d'administration
Séparation	**effacement par qui compromet le cloud**	pile externe, administrée par d'autres personnes
Accès restreint	**fuite de données personnelles, détournement**	comptes Grafana nominatifs, rôles de lecture, mot de passe initial changé
Intégrité	**preuve contestable**	stockage en écriture seule ou objet verrouillé ; copie vers le SIEM
Conservation	**enquête impossible, ou conservation illégale**	durée décidée — six mois à un an — et purge automatique
Santé de la chaîne	**trou de collecte non détecté**	alerte sur source muette ; test mensuel de bout en bout
Capacité	**perte des journaux les plus récents**	dimensionnement initial, alerte à 80 % du stockage

> **Test de bout en bout :** provoquer un événement connu — un échec d'authentification avec un compte d'essai —, puis le retrouver dans Grafana et dans le SIEM, avec la bonne heure.

Bonnes pratiques et erreurs fréquentes

Réseau

Erreur	Correction
Un réseau partagé « pour simplifier »	réseaux privés ; RBAC ciblé
Règles ajoutées au groupe `default`	groupes par rôle
Ouverture par adresse plutôt que par groupe	groupe distant
Sécurité de port désactivée pour une adresse virtuelle	paires d'adresses autorisées
Adresse flottante sur chaque serveur	un répartiteur ou un bastion
Règles sans description	une description par règle

Journalisation

Erreur	Correction
Se fier aux journaux des pods	centraliser : ils disparaissent au redémarrage
Niveau WARNING sur les API	INFO pour garder les accès
Échecs d'authentification non émis	les réactiver
Horloges non synchronisées	NTP partout, supervisé
Pile de journaux dans le cloud surveillé	pile externe
Aucune alerte sur la collecte	alerte sur source muette
DEBUG laissé actif	fenêtre datée, retour au niveau normal

Exercices de mise en pratique

#	Énoncé
1	**Inventorier les réseaux partagés et les politiques RBAC du cloud ; justifier ou supprimer chacun.**
2	**Déployer l'application à trois niveaux avec ses cinq groupes ; jouer le tableau de tests de cloison.**
3	**Partager un réseau d'administration avec un seul projet ; vérifier qu'un troisième projet ne le voit pas.**
4	**Supprimer une instance d'essai ; retrouver, à partir de son nom, l'utilisateur, l'heure et l'identifiant de requête, puis toutes les lignes associées dans Loki.**
5	**Écrire la requête qui compte les échecs d'authentification par utilisateur sur une heure, et en faire une alerte.**
6	**Couper la collecte d'une source ; vérifier que l'alerte « source muette » se déclenche.**

Corrigé — points clés

- **1 :** `network list --long` et `network rbac list --long` ; toute cible « * » hors réseau externe est suspecte.
- **2 :** refus = délai dépassé ; vérifier aussi que `default` n'est plus sur les ports.
- **3 :** le projet non ciblé ne voit pas le réseau dans `network list`.
- **4 :** `server event list` → identifiant de requête → recherche dans Loki ; nom d'utilisateur par son identifiant dans Keystone.
- **5 :** filtrer « Authorization failed » puis `count_over_time` ; seuil et destinataire documentés.
- **6 :** sans alerte de collecte, un trou de journaux passe inaperçu — c'est l'objet de l'exercice.

> Prérequis du TP : cloud Sunbeam avec `admin-openrc`, deux projets, observabilité activée, accès à Grafana.

SYNTHÈSE

Ce qu'il faut retenir

Réseaux

- Réseau privé par projet par défaut : isolation de niveau 2.
- Partage rare, ciblé par RBAC, jamais `--share`.
- Exposition par adresses flottantes, sous quota.
- Réseau externe réservable à certains projets.

Micro-segmentation

- Groupes par rôle, règles par groupe distant.
- `default` laissé intact et retiré des ports.
- Sécurité de port toujours active.
- Filtrage distribué par OVN sur chaque hyperviseur.

Audit et traçabilité

- Identifiant de requête : le pivot de toute enquête.
- Événements d'instance, notifications CADF, lignes d'accès.
- Centralisation hors du cloud, horloges synchronisées.
- Conservation de six mois à un an ; alertes, dont la collecte elle-même.

Question	Réponse courte
Qu'est-ce qui isole deux locataires ?	**réseaux privés, routeurs distincts, groupes de sécurité — et aucun partage non voulu**
Comment segmenter une application ?	une matrice de flux, un groupe par rôle, une règle par flux
Comment retrouver qui a fait quoi ?	événement → identifiant de requête → journaux centralisés → utilisateur
Sur Sunbeam ?	`sunbeam enable observability` (de préférence externe) ; niveaux de journalisation par `juju config`

Sources : documentation de Neutron (RBAC, journalisation des flux, fonctionnalités OVN), client OpenStack (règles par défaut des groupes), Keystone (notifications), keystonemiddleware (audit), Canonical OpenStack 2026.1 (observabilité), ANSSI (architecture d'un système de journalisation), CNIL (recommandation journalisation, 2021) — consultées en octobre 2026.